

RAPPORT DE TRAVAUX PRATIQUES

Simulation et Détection d'Attaque Phishing

Étudiante	Sara Aroui
Encadreur	Dr. Nabil Messaoudi
Spécialité	Master Sécurité Informatique
Établissement	Université Abbès Laghrour de Khenchela
Année Universitaire	2025-2026
Module	Cybercriminalité & Sécurité Informatique

Date de soumission : 03 May 2026

Table des Matières

1. Introduction et Objectifs	3
2. Environnement Technique et Outils	3
3. Phase 1 — Simulation de Page Phishing	4
4. Phase 2 — Analyse Forensique des En-têtes Email	5
5. Phase 3 — Dashboard de Détection (SIEM)	6
6. Règle YARA Générée	7
7. Résultats et Discussion	8
8. Recommandations de Sécurité	8
9. Conclusion et Références	9

1. Introduction et Objectifs

Ce rapport documente le Travail Pratique réalisé dans le cadre du module de Cybercriminalité et Sécurité Informatique, en Master Sécurité Informatique à l'Université Abbès Laghrour de Khenchela. Ce TP porte sur la simulation d'une attaque de phishing, son analyse forensique et la mise en place de mécanismes de détection automatisés.

Le phishing représente aujourd'hui l'une des formes d'attaque les plus répandues dans le domaine de la cybercriminalité. Plus de 90% des cyberattaques débutent par un email de phishing. Ce TP vise à comprendre ces mécanismes en profondeur afin de mieux les contrer.

Objectifs Pédagogiques

- Comprendre les techniques d'ingénierie sociale utilisées dans les attaques de phishing.
- Analyser les en-têtes SMTP pour identifier l'origine et la légitimité d'un email.
- Identifier les Indicateurs de Compromission (IOC) associés à une attaque.
- Développer des règles de détection YARA et SIEM pour contrer ces attaques.
- Documenter le processus d'investigation selon une méthodologie professionnelle.

2. Environnement Technique et Outils

L'intégralité du TP a été réalisée dans un environnement virtuel sécurisé (CyberLab Simulator), sans connexion à des systèmes réels, conformément aux exigences éthiques et légales.

Outil / Composant	Version	Rôle dans le TP
CyberLab Simulator	v1.0	Plateforme principale du TP
Analyseur SMTP	Intégré	Analyse des en-têtes email
Moteur YARA	v4.3	Génération des règles de détection
SIEM Dashboard	Personnalisé	Monitoring et alertes en temps réel
VirusTotal / AbuseIPDB	En ligne	Réputation IP et domaine (OSINT)

3. Phase 1 — Simulation de Page Phishing

3.1 Principe de l'Attaque

Dans cette phase, nous avons simulé la création d'une page de login frauduleuse imitant le réseau social Facebook. L'attaque repose sur le typosquatting : utilisation d'un nom de domaine visuellement similaire au domaine légitime pour tromper la victime.

Domaine légitime : facebook.com → **Domaine malveillant : facebo0k-secure.net**

3.2 Email de Phishing Généré

FROM: security@facebo0k-secure.net
REPLY-TO: no-reply@malicious-server.xyz
TO: victime@entreprise.com
SUBJECT: ■ Votre compte a été compromis — Action requise
X-MAILER: PhishKit v3.2
PHISHING-URL: https://facebo0k-secure.net/login?token=phish_xyz_001

3.3 Indicateurs de Compromission (IOC) Identifiés

Indicateur (IOC)	Valeur / Description	Sévérité
Domaine typosquatté	facebo0k-secure.net	CRITIQUE
Substitution caractère	o → 0 (zéro à la place de lettre o)	CRITIQUE
Certificat SSL	Auto-signé / inexistant	ÉLEVÉE
SPF	spf=fail	CRITIQUE
DKIM	dkim=fail	CRITIQUE
DMARC	p=none (aucune protection)	ÉLEVÉE
Enregistrement domaine	Créé il y a moins de 30 jours	MOYENNE
Return-Path	Différent du champ From (spoofing)	CRITIQUE
X-Mailer	PhishKit v3.2 — outil de phishing	CRITIQUE

4. Phase 2 — Analyse Forensique des En-têtes Email

4.1 Méthodologie d'Analyse

L'analyse des en-têtes SMTP constitue l'étape centrale de l'investigation forensique d'un email suspect. Elle permet de retracer le chemin parcouru par l'email et d'identifier son origine réelle, indépendamment des informations affichées à l'utilisateur.

4.2 En-têtes SMTP Analysés

```
Received: from mail.evil-sender.ru (185.220.101.45)
    by mx.victim.com with SMTP id xyz123
From: "Facebook Security" <security@facebook-secure.net>
Reply-To: <noreply@malicious-server.xyz>
Return-Path: <bounce@evil-sender.ru>
X-Originating-IP: 185.220.101.45
X-Mailer: PhishKit v3.2
Authentication-Results: spf=fail; dkim=fail; dmarc=fail p=none
```

4.3 Résultats des Mécanismes d'Authentification

Mécanisme	Résultat	Score	Signification
SPF	FAIL	5/100	Domaine non autorisé à envoyer des emails
DKIM	FAIL	10/100	Signature cryptographique invalide ou absente
DMARC	NONE/FAIL	15/100	Aucune politique de rejet configurée
Réputation domaine	BLACKLISTÉ	8/100	AbuseIPDB Score: 97% — Domaine malveillant

4.4 Analyse de l'IP Source

Adresse IP	185.220.101.45
Géolocalisation	Russie (RU) — Moscou
Type de nœud	TOR Exit Node — Réseau Tor (anonymisation)
Score AbuseIPDB	97% — Très haute probabilité malveillante
Listes noires	Spamhaus, SORBS, Barracuda — Blacklistée
ASN	AS24940 — Hetzner Online GmbH

Conclusion Phase 2 : L'email analysé présente tous les signes d'une attaque de phishing sophistiquée. L'utilisation d'un nœud TOR démontre une tentative délibérée d'anonymisation. **Score de menace global : 94/100 — CRITIQUE**

5. Phase 3 — Dashboard de Détection (SIEM)

5.1 Statistiques Globales (7 jours simulés)

247 Tentatives détectées	231 Emails bloqués	93% Taux de détection	5 Règles actives
-----------------------------	-----------------------	--------------------------	---------------------

5.2 Activité des Attaques sur 7 Jours

Jour	Tentatives	Niveau de Risque
Lundi	18	Faible
Mardi	34	Modéré
Mercredi	22	Faible
Jeudi	61	Élevé
Vendredi	89	Critique
Samedi	47	Modéré
Dimanche	38	Modéré

5.3 Alertes de Sécurité en Temps Réel

- [CRITIQUE] Phishing Email Bloqué — FROM: security@facebook-secure.net | SPF/DKIM FAIL | IP: 185.220.101.45
- [CRITIQUE] Domaine Typosquatté Détecté — facebook-secure.net — Enregistré il y a 3 jours
- [ALERTE] Tentative de Login Suspecte — 3 tentatives depuis IP TOR — 185.220.101.45
- [ALERTE] Encodage Base64 dans Subject — Obfuscation détectée dans l'en-tête Subject
- [INFO] Scan de ports entrant — Port 25/587 — Source: 203.0.113.5

6. Règle YARA Générée Automatiquement

Sur la base des IOC collectés durant les phases précédentes, la règle YARA suivante a été générée pour permettre la détection automatisée d'emails similaires :

```
rule Phishing_Email_Detection {
  meta:
    author      = "Sara Aroui – TP Cybercriminalité"
    description = "Détection email phishing – Simulation Facebook"
    severity    = "CRITICAL"
    date        = "2025-05-02"

  strings:
    $domain     = "facebo0k-secure.net" nocase
    $ip          = "185.220.101.45"
    $spf_fail    = "spf=fail" nocase
    $dkim_fail   = "dkim=fail" nocase
    $return_path = "evil-sender" nocase
    $mailer      = "PhishKit" nocase

  condition:
    ($domain or $ip) and
    ($spf_fail or $dkim_fail) and
    $return_path
}
```

6.1 Règles SIEM Déployées

Nom de la Règle	Type	Correspondances (7j)
SPF_DKIM_FAIL_BLOCK	SIEM	47 hits
TOR_EXIT_NODE_BLOCK	Firewall / SIEM	23 hits
TYPOSQUATTING_DETECT	YARA	12 hits
BASE64_SUBJECT_FLAG	SIEM	8 hits
NEW_DOMAIN_FLAG	Threat Intelligence	5 hits

7. Résultats et Discussion

7.1 Synthèse des Résultats

Phase	Résultat Principal	Performance
Phase 1 — Simulation	9 IOC identifiés sur la page phishing et l'email	100%
Phase 2 — Analyse Headers	Origine confirmée, SPF/DKIM/DMARC: FAIL, IP TOR	Score 94/100
Phase 3 — Détection SIEM	231/247 emails malveillants bloqués	Taux 93%

7.2 Discussion

- Le taux de non-détection de 7% correspond aux emails contournant les règles via des techniques avancées (domaines légitimes compromis, DKIM valide via comptes piratés).
- L'utilisation du réseau TOR démontre une sophistication croissante des cybercriminels dans leur volonté d'anonymisation.
- L'absence de politique DMARC stricte (p=reject) reste l'un des principaux facteurs facilitant le spoofing d'identité.
- Le pic d'attaques observé le vendredi confirme les statistiques de l'industrie sur les tentatives de phishing en fin de semaine.

8. Recommandations de Sécurité

1. Authentification Email (SPF/DKIM/DMARC)

Configurer une politique DMARC stricte (p=reject) sur tous les domaines. Mettre en place DKIM avec des clés de 2048 bits. Vérifier et corriger les enregistrements SPF.

2. Sensibilisation des Utilisateurs

Former régulièrement les utilisateurs à reconnaître les signes d'un email de phishing : urgence artificielle, URL suspecte, expéditeur inconnu. Organiser des simulations régulières.

3. Surveillance Continue (SIEM)

Déployer un SIEM avec les règles de détection développées dans ce TP. Configurer des alertes en temps réel et maintenir une threat intelligence à jour.

4. Filtrage DNS et Web

Utiliser des solutions de filtrage DNS (Cisco Umbrella, Cloudflare Gateway) pour bloquer automatiquement les domaines malveillants.

5. Réponse aux Incidents

Définir une procédure de réponse incluant l'isolation des machines compromises, la notification des utilisateurs affectés, et la mise à jour des règles de détection.

9. Conclusion et Références

Ce travail pratique a permis d'explorer de manière complète et structurée le cycle de vie d'une attaque de phishing, depuis sa conception jusqu'à sa détection et son analyse forensique. Réalisé dans un environnement virtuel sécurisé, ce TP illustre parfaitement les défis actuels de la cybersécurité et les mécanismes de défense disponibles.

Les compétences acquises — analyse d'emails suspects, investigation OSINT, développement de règles YARA/SIEM, et documentation technique — sont directement applicables dans un contexte professionnel de sécurité informatique.

La lutte contre le phishing nécessite une approche holistique combinant des solutions techniques robustes (SPF/DKIM/DMARC, SIEM, filtrage DNS), une sensibilisation continue des utilisateurs, et des procédures de réponse aux incidents bien définies. Ce TP démontre que des outils accessibles, correctement configurés et combinés, permettent d'atteindre des taux de détection supérieurs à 90%.

Score final de détection : 94/100 | Taux de blocage : 93% | Menace : CRITIQUE détectée et neutralisée

Références

- [1] MITRE ATT&CK; — Technique T1566: Phishing — <https://attack.mitre.org/techniques/T1566/>
- [2] OWASP — Email Header Injection & Phishing Prevention Cheat Sheet — <https://owasp.org>
- [3] NIST SP 800-177 — Trustworthy Email — National Institute of Standards and Technology
- [4] AbuseIPDB — IP Reputation Database — <https://www.abuseipdb.com>
- [5] VirusTotal — Domain and URL Analysis — <https://www.virustotal.com>
- [6] YARA Documentation v4.3 — <https://yara.readthedocs.io>
- [7] RFC 7489 — Domain-based Message Authentication (DMARC)
- [8] Kaspersky Security Bulletin 2024 — Spam and Phishing Report